

BigBrother SIEM-aaS

A multi-tenant security monitoring platform — built, hardened, and proven live against its own configuration.

Team Great Wall



Live demo: cloud bastion → on-prem SIEM → offline CA • Presentation 16 & 18 JUN 2026

bigbrother

Cloud bastion

AWS • Rocky 10 • ARM

WireGuard hub • SSH gateway



 **siem**

On-prem SIEM

Rocky 10 • Wazuh 4.14

Multi-tenant monitoring



vault-ca

Offline-style CA

Rocky 9 • Vault PKI

Twingate ZTNA only

Executive Summary

OVERVIEW

What it is, the risk it manages, and how we prove it.

The platform

- Multi-tenant SIEM-as-a-service: one Wazuh brain monitors four client tenants across three hardened hosts — cloud bastion, on-prem SIEM, offline-style Vault CA.
- Defense in depth and least privilege throughout. Identity is short-lived (8h certificates); the trust root has no public exposure.
- Built from code (Ansible + CI), measured with CIS, and provable on a live terminal.

Proven live today

- Tenant isolation enforced inside the datastore — a fully authenticated admin is refused cross-tenant with HTTP 403.
- One 8h Vault-signed certificate logs into both the bastion and the SIEM — same CA fingerprint, two post-quantum handshakes.
- Hardening measured, not claimed — CIS Level 1 at 85 / 82 / 92.

► **PROVEN LIVE** Three proofs, each re-runnable on request

Architecture

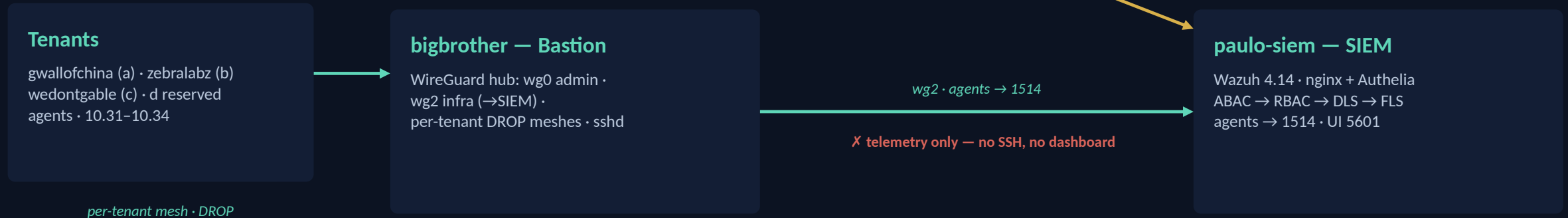
ENVIRONMENT

Two planes that never mix: operators via Twingate; tenants & agents via the bastion — telemetry only.

OPERATOR PLANE — Team Great Wall



TENANT / TELEMETRY PLANE — agents & clients

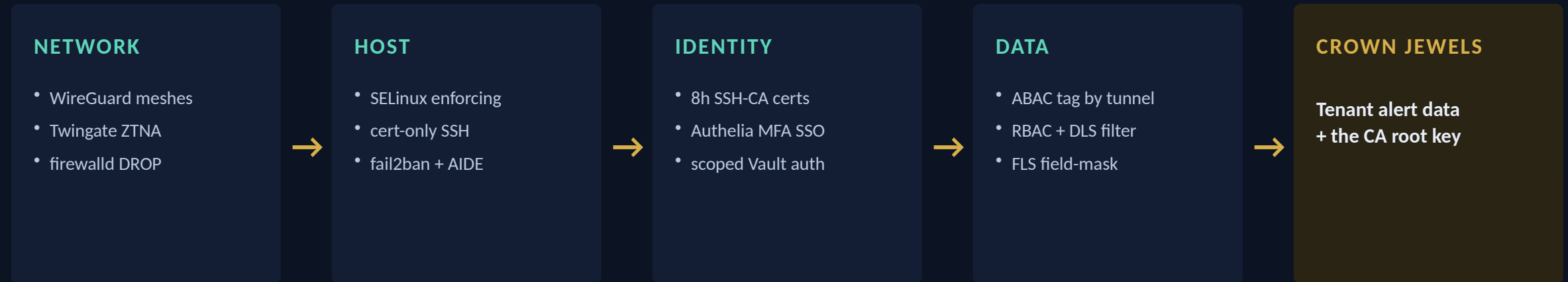


The difference: tenants & agents reach the SIEM only through the bastion's tunnels, only on 1514 — they can never SSH or see a dashboard. Operators reach SSH & the dashboard only via Twingate + MFA. Two planes, two identities, never mixed.

Defense in Depth

10%

Concentric controls on the path to the data; an attacker must beat every one.



CROSS-CUTTING — detect & recover (spans every layer, not a hop on the path)

Monitoring Wazuh SIEM (4 agents) + Vault audit log detect activity at every layer. **Recovery** encrypted Vault snapshots + LVM snapshots restore after a failure.

Beating one control still meets the next; detection and recovery underpin all of them.

Multi-Tenant Isolation

ACCESS CONTROL • 10%

Four models stacked on the SIEM, and we verified enforcement, not intent.

Four models, stacked

- ABAC — an ingest pipeline tags each alert's tenant from its WireGuard source subnet; forgery-resistant (trusts the tunnel, not a label).
- RBAC — four per-tenant roles, scoped index patterns, monitor-only; no user spans tenants.
- DLS — each role filters documents to its own tenant term.
- FLS — masks sensitive fields (agent.key, config_sum, wazuh.cluster).

Verified enforcement — 32 PASS / 0 FAIL

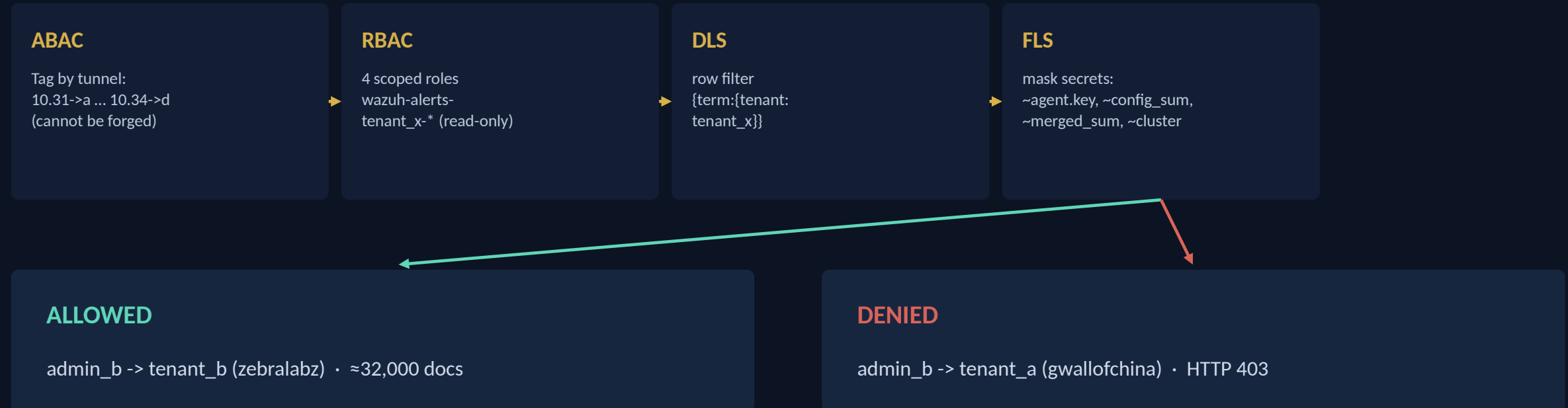
- admin_b reads tenant_b (zebralabz) → its own data (≈32k docs) ✓
- admin_b reads tenant_a (gwallofchina) → HTTP 403, security_exception ✗
- 0 mis-tagged documents in any tenant index.
- Operators (Twingate) and infra hosts never appear in client data.

► **PROVEN LIVE** `curl -u admin_b .../wazuh-alerts-tenant_a/_search → 403 security_exception`

Isolation — how a query is narrowed

ACCESS CONTROL · 10%

One query passes four filters; only its own tenant's data survives — and we verified the denial.



Multi-Tenant Footprint

ACCESS CONTROL • 10%

The data behind the 403: one shared SIEM, four isolated tenant indices.

79,757

alerts indexed

4

Wazuh agents

90 days

ISM retention / tenant

0

cross-tenant leaks

Documents per tenant index (wazuh-alerts-tenant_X-*)



Why it matters

Tenants share one cluster but live in separate indices. zebralabz holds ~32k docs; gwallofchina ~1.5k. The 403 is what stops zebralabz's admin from ever reading that gwallofchina data — proven live on the previous slide.

Hardening

BONUS • 10%

A measured number per host, re-runnable live, not a checkbox.

85%

bigbrother

Rocky 10 • CIS L1

82%

paulo-siem

Rocky 10 • CIS L1

92%

vault-ca

Rocky 9 • CIS L1

OpenSCAP • CIS Server Level 1

- Post-quantum SSH key exchange on all three hosts — sntrup761 on the bastion and CA, ML-KEM-768 on the SIEM.
- yescrypt password hashing; AEAD-only ciphers; certificate auth with no passwords or root login.
- requiretty enforced on the internet-facing bastion — a CIS control kept where the threat is highest.
- Honest scope: these are CIS Level 1 scores; the earlier 64→74% was the stricter Level 2 — separate rulers, not blended.

► **PROVEN LIVE** `oscap xccdf eval --profile cis_server_l1 → 85 / 82 / 92`

Risk Register

GOVERNANCE

Every known gap — named, rated, mitigated, and owned.

Risk	Likelihood	Impact	Mitigation	Status
Single-node Vault CA (no failover)	Low	High · availability	8h certs + break-glass keys survive an outage; 3-node HA + auto-unseal staged in IaC	Planned
Long-lived Vault root token	Low	High · privilege	Not stored, not used day-to-day; scoped vault-admin default is the fix	In progress
Backups on-host only	Medium	Medium · recovery	Verified restorable Vault snapshot; off-site replication is next	In progress
SIEM accepts certs + static keys	Low	Low · identity	Additive by design; static keys are documented break-glass, removed after cert rollout	Accepted
SIEM is internet-facing	Medium	Medium · exposure	Twingate-only management, default-DROP firewall, CIS-hardened, patch cadence	Mitigated

How we treat risk: we surface our own gaps, rate them, and attach a mitigation and a status — managed risk, not hidden risk.

Conclusion & Reflection

10%

What we learned and where we take it next.

Lessons learned

- Test backups by restoring them — a verified snapshot, not a schedule, is the recovery path.
- Measure hardening as a number, and keep CIS L1 / L2 rulers separate.
- Verify isolation by enforcement (the 403), not by description.

Suggestions for improvement

- Finish team-wide cert rollout, then cut bastion + SIEM to cert-only (retire static keys).
- Move Vault to a 3-node Raft cluster with auto-unseal; off-site backup replication.
- Make a scoped vault-admin login the default; keep the root token strictly break-glass.
- Bring the CA under central monitoring via an outbound-only agent.
- Hold a regular patch cadence on the public-facing SIEM.

Defense in depth — measured, code-managed, and provable. Every claim in this deck can be demonstrated live on all three hosts.

Access Control

10%

Least privilege for operators and the dashboard (tenant isolation next slide).

Operator login — short-lived certs

- Bastion AND SIEM trust the same Vault SSH-CA — operators log in with 8-hour, OIDC-issued certificates.
- No long-lived `authorized_keys` to manage: hosts trust the CA, not a key list. SSH `AllowUsers` whitelist — five named operators.
- Twingate ZTNA fronts every operator path (MFA + device posture).

Dashboard & SSO

- Authelia SSO — TOTP / WebAuthn, default-deny — fronts the dashboard via nginx.
- No raw dashboard exposure; reverse-proxy + ForwardAuth only.
- `userpass` break-glass in Vault; everything else is SSO.

► **PROVEN LIVE** `ssh-keygen -L cert · sshd -T | grep trustedusercakeys (bastion + SIEM)`

Network Defense

10%

Segmented meshes and a CA with no public exposure.

Segmentation — bastion

- Separate tunnels by role: admin (wg0) and infra→SIEM (wg2), plus a per-tenant mesh per client (wg-gwall/zebra/wdg). wg1, a legacy tunnel, has been retired (interface down).
- Per-tenant firewall zones, default-DROP, one per tenant interface.
- Cross-tenant and intra-tenant traffic is rejected by rule.

Exposure — CA

- No public IP; WireGuard fully removed.
- Twingate outbound connector only (nickel-caracal) — nothing inbound to scan.
- Host firewall defaults to DROP; SSH and Vault reached only over the outbound Twingate tunnel — no management port exposed inbound.

► **PROVEN LIVE** `firewall-cmd --zone=tenant-zebra --list-rich-rules`

Host Defense

10%

Mandatory access control, intrusion defence, and SSH lockdown.

Mandatory controls

- SELinux Enforcing and auditd active on all three hosts.
- fail2ban guarding the SSH jail on the bastion.
- AIDE file-integrity monitoring runs daily (~90,000 files baselined).

SSH lockdown

- Certificate auth only — no passwords, no root login, anywhere.
- maxauthtries 3, 30-second login grace; X11 off, AllowUsers whitelist.
- Break-glass SSH port stays closed at the AWS security group — opened only in emergencies; key-only, wrong key triggers a ~1-week ban.

► **PROVEN LIVE** `sshd -T | grep kex/allowusers · getenforce · fail2ban-client status`

Logging & Monitoring

10%

Centralised telemetry, tenant-aware retention, and an audited trust root.

SIEM telemetry

- Wazuh 4.14 — four agents reporting (bastion, SIEM, two tenant hosts).
- Security Config Assessment, file-integrity monitoring, active-response enabled.
- Threat-intel CDB lists in use (malicious-IOC, audit-keys).

Retention & audit

- 90-day index lifecycle (ISM) with per-tenant retention policies.
- Vault audit device records every CA operation — issuance and login.
- Indexer access itself is audited (security-auditlog index).

► **PROVEN LIVE** `agent_control -l · vault audit list · _ism/policies`

Backup Management

10%

Scheduled backups, and an honest account of testing them.

What we back up

- Encrypted Vault raft snapshots (AES-256), 7-day retention, nightly.
- SIEM config/data backup job staged in /opt/siem-lab/backups (still being finalized).
- LVM logical volumes with snapshots underneath.

Tested, not assumed

- A pre-demo audit caught a backup silently failing — a dead Vault token — before we ever relied on it.
- Fixed it and verified a real, restorable Vault snapshot; the SIEM job is still being finalized.
- Next step: off-host / offsite replication.

► **PROVEN LIVE** `ls -lh /opt/vault/backups` → verified raft snapshot on disk

Redundancy Measures

10%

What is resilient today, and what we have honestly scoped as next.

What we have

- Encrypted Vault snapshots provide a tested, restorable recovery path.
- Designed break-glass: a scoped static key reaches each host if the Vault CA is ever unavailable — the trust root never depends on the certs it issues.
- The bastion is rebuildable from the Ansible baseline (Elastic IP + IaC).

What's next — scoped

- Vault storage is HA-capable; production profile scales to a 3-node Raft cluster with auto-unseal.
- Move backups off-host with offsite replication.
- LVM snapshots today; software RAID is a planned add.

► **PROVEN LIVE** vault status (raft) · ls /opt/vault/backups · snapshot restore (rehearsed)

IAM & Key Management

10%

Scoped identities and a two-tier PKI with real revocation.

Identities & auth

- Vault four auth methods: OIDC (Google SSO), AppRole (machines), userpass (break-glass), token.
- Purpose-scoped service policies — ssh-admin, siem-backup, vault-backup.
- SSH-CA role: 8-hour TTL, five named principals.

PKI & keys

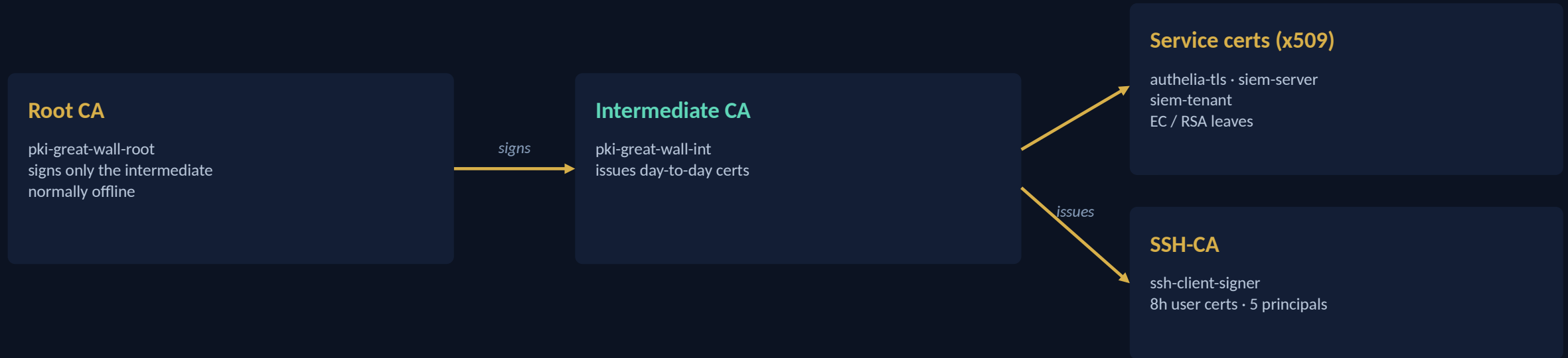
- Two-tier PKI: root → intermediate; intermediate signs day-to-day.
- Issuing roles scoped per service: EC P-256 (Authelia TLS), RSA-2048 (SIEM server + tenant).
- Revocation is real: 72h CRL + OCSP responder. Root normally offline — loaded only for the demo.

► **PROVEN LIVE** `vault auth list · pki-great-wall-int/config/crl (OCSP on)`

Two-Tier PKI

IAM & KEY MANAGEMENT • 10%

An offline root signs one intermediate; the intermediate does the day-to-day issuing, with real revocation.



Revocation is real: CRL (72h) + OCSP enabled — a compromised cert can be killed before it expires.

SSH-CA Trust Chain

IAM • proven live

One 8h Vault-signed cert — accepted by BOTH the bastion and the SIEM, because both trust the same CA.



Same fingerprint on every end — the CA that signs the cert (2) is exactly the CA both the bastion AND the SIEM trust:
SHA256:aAn1L9Hnqbd7Mu6to8P94QJdJgQgOSQtq+SSzn19HSw. One short-lived cert, two hosts, two post-quantum handshakes — the chain closes.

Repeatable Architecture

BONUS • 10%

The whole platform is built from code and gated by CI.

Infrastructure as code

- Ansible roles: common (hardening, users, SSH-CA, fail2ban), bastion, vault-ca, tenant-onboarding.
- Jinja-templated; one repository rebuilds the baseline for every host.
- Tenant onboarding automated — ingest pipeline, role, role-mapping, API user.

CI & quality gates

- Every push runs yamllint, ansible-lint, gitleaks secret-scan, syntax-check — pipeline green.
- 57 commits of tracked, reviewed change history.
- laptop / mid / production profile toggle (JVM heap, replicas, agents).

► **PROVEN LIVE** `git log --oneline` · CI: lint + gitleaks + syntax-check green

Anticipated Questions

answers on the slide

The questions a reviewer asks — answered here, provable on request.

Q A tenant agent is compromised — can it forge its tenant tag to read another's data?

A No. The ingest pipeline tags by WireGuard source subnet, not a self-reported field. To appear as another tenant it would need that tenant's private key. ABAC trusts the tunnel, not the claim.

Q What's your single point of failure, and what's the blast radius?

A The CA: single-node Vault. If it's down, no new certs issue — but existing 8h certs keep working and break-glass keys remain. It's an availability gap, not confidentiality. Fix: 3-node HA + auto-unseal.

Q Why trust WireGuard subnets for identity — isn't that just IP-based auth?

A The placement is cryptographic, not IP-claimed: WireGuard assigns the interface by the peer's key. You can't spoof onto a mesh without the private key, so the tag is as strong as the key.

Q Post-quantum SSH — marketing, or a real threat model?

A Harvest-now-decrypt-later: record sessions today, decrypt once quantum hardware exists. Hybrid KEX (sntrup761 / ML-KEM-768) is no weaker than classical now — cheap insurance for long-lived secrets.

Q Walk the kill-chain: one tenant host is popped — how far does the attacker get?

A Mesh-isolated by firewalld DROP; no pivot to other tenants or the SIEM (telemetry-only, 1514). SELinux confines the process, no static keys to harvest, and the data layer returns 403 cross-tenant. Every step alerts in Wazuh.

Q How do you revoke access before a cert's 8h TTL expires?

A Revoke the serial — the 72h CRL + OCSP responder propagate it. Short TTL bounds exposure; revocation handles the in-window case.

Q Where could privilege escalation still bite you?

A A long-lived Vault root token exists — kept as break-glass because OIDC fails locally on the CA. Not stored, not used day-to-day; fix is a scoped vault-admin default. We found it in our own audit and flag it.

Q Detection vs prevention — what do you catch, and what would you miss?

A Wazuh fires on FIM changes, auth failures, SELinux denials (severity-tagged, kept 90d). Gap we own: no SOAR/auto-response or paging yet — detection + retention are in, orchestration is roadmap.